

EU AI ACT PACK

Data Deletion Runbook

Operational procedure — GDPR erasure

Lexy AI Hiring Platform · Generated 2026-07-20

Factual description of the system as built. Not legal advice; assumptions flagged for counsel.

When a candidate submits a deletion request via `/portal/deletion-request`, a row is inserted into `deletion_requests` with status `pending`. This runbook covers turning that row into actual data deletion.

Statutory clocks

Jurisdiction	Clock	Extendable?
IL AIVI Act	30 days from request	No
GDPR (EU/UK)	30 days	Yes, to 90 days if complex
CCPA / CPRA (CA)	45 days	Yes, to 90 days
Other	Apply the 30-day default	—

The admin tool surfaces the clock per request — never wait past it. If a request is approaching the clock, raise to founder before missing.

Step-by-step

1. Triage (within 2 business days of request)

1. Open `/admin/deletion-requests` as `platform_admin`.
2. Confirm identity by matching `candidateEmailSnapshot` against the submitting session. If the submitter could not be matched to a logged-in candidate session, the candidate must verify by email before fulfilment (send an email to the snapshot address with a confirmation link).
3. Check for legal hold:
 - Is the candidate party to an open dispute, lawsuit, or fraud investigation? If yes, status → `denied` with note “legal hold — counsel”. Notify the candidate that the request is denied for legal-hold reasons, with the statutory basis (see GDPR Article 17(3)(e)).
4. If clear to proceed, set status to `in_progress` and assign yourself.

2. Fulfilment

Click **Fulfil** in the admin tool. This performs the following:

- **Inside a single DB transaction:** explicit `DELETE FROM <table> WHERE candidate_id = $1` against every candidate-linked table (current count is enumerated as `CANDIDATE_LINKED_TABLES` in `routes/admin-deletion.ts` — 38 tables as of 2026-05-16), followed by `DELETE FROM candidates WHERE id = $1`, and finally the `deletion_requests` row is flipped to `fulfilled` so partial deletions cannot leak through. If any statement fails the whole transaction aborts and the request stays `in_progress` for the operator to retry.
- **After the transaction commits:** an audit row is written with `action="candidate.deletion_fulfilled"`, `subject_id=<candidateId>`, `subject_label="deleted-candidate"`, and metadata including `{ requestId, jurisdiction, emailSnapshot, tablesCascaded }`. The audit row is intentionally written **outside** the transaction so a rolled-back cascade can never leave a misleading “fulfilled” entry in `audit_logs`.

We do **not** delete the audit-log rows themselves — the retention basis is “establishment / exercise / defence of legal claims” (GDPR Article 17(3)(e)) and our immutable-audit-trail policy. The candidate’s

email is retained on the `deletion_requests` row for the same reason, so the regulator can later verify that the fulfilment notification was sent.

Object storage cleanup (future): uploaded resume PDFs and interview recordings stored outside Postgres are NOT yet deleted by the Fulfil action. Until an object-storage sweep is added, the operator must manually issue the equivalent cleanup against the S3 / object-storage bucket using the `candidateId` from the request (the `candidates` row will already be deleted, so capture the id before clicking Fulfil). Tracked as a follow-up.

3. Notification

Send a confirmation email to `candidateEmailSnapshot` :

Subject: Your data deletion request — completed

Hi,

We're confirming that we have completed your deletion request submitted on {date}. We have deleted your candidate profile, resume, interview recordings and transcripts, and demographic information from Lexy.

Per legal retention requirements, we retain an immutable audit log that records that the deletion took place (but not the data itself). No personally identifying information about you remains in our systems.

If you believe data about you still remains, please reply to this email.

— Lexy

4. Edge cases

- **Candidate is an active employee of a Lexy Customer.** Deletion removes the candidate row; if they re-apply they will be onboarded fresh. Notify the Customer's recruiter contact as a courtesy.
- **Candidate is mid-interview.** Politely confirm with the candidate that they want to abandon the interview. If yes, proceed.
- **Multiple Customers have the same candidate.** Today, deletion is global — the candidate is deleted from every Customer's view. Future feature: per-Customer deletion. Document the global behaviour in the confirmation email.

What does not get deleted

- `audit_logs` rows — retained, tombstoned (legal-hold basis).
- `deletion_requests` row itself is kept (status → `fulfilled`) so we can produce the audit trail to a regulator. The candidate's email snapshot is retained on that row to prove the notification was sent to the right address.
- Aggregate analytics ($k\text{-anonymity} \geq 5$) — these are not personal data by definition.

Escalation

- Statutory clock approaching: founder.
- Legal-hold suspected: outside counsel before status → `denied`.

- Suspected fraudulent request: do NOT fulfil; raise to founder with evidence. A fulfilled fraudulent request is a data-breach equivalent.